Note de cadrage CTI Helios Energy

Incident INC-2026-0302 | 5 octobre 2026 | Version 0.1

Objectif et destinataires

Nous analysons l'intrusion décrite dans le dossier d'Helios Energy, fournisseur d'énergie fictif de 3 000 salariés présenté comme opérateur d'importance vitale. L'enquête vise à reconstituer l'attaque, évaluer ses conséquences et examiner une attribution argumentée. La direction recevra une synthèse des risques ; le SOC recevra les preuves, les techniques observées et les propositions de détection.

Périmètre de l'investigation

La période initiale examinée va du 2 au 7 mars 2026, en UTC. Les événements suspects concernent principalement comptabilite-07, srv-fichiers-02 et dc-01. Les autres hôtes cités restent à évaluer : leur présence dans les indicateurs ne suffit pas à établir leur compromission. Le périmètre inclut les fichiers décrits, les infrastructures associées, les alertes et les journaux fournis.

Sont exclus les tests d'intrusion, les connexions aux infrastructures citées, la remédiation sur un système réel et l'exécution de fichiers malveillants. Les domaines et IP sont des valeurs de documentation. Les trois fiches d'analyse remplacent les échantillons, qui ne sont pas fournis. Toute consultation liée au dark web restera passive, tracée et horodatée, sans interaction ni achat, conformément au sujet.

Hypothèses de départ et questions ouvertes

Les pièces orientent vers un accès initial par document Office, l'installation d'une charge persistante, des communications de commande et contrôle et des activités suspectes sur d'autres hôtes. L'accès à LSASS et le volume sortant important justifient d'examiner un vol d'identifiants et une exfiltration. Chaque lien causal reste à démontrer. Le contenu des données transférées, l'étendue des accès et la présence résiduelle de l'attaquant sont inconnus.

La piste FIN7/Carbanak proposée dans le dossier sera examinée comme une hypothèse. Aucun groupe, acteur étatique ou rançongiciel ne sera déclaré responsable sans éléments suffisants. Les écarts Excel/Word, les dates du mémo et la chronologie du compte svc-backup-temp seront consignés et soumis au formateur pour arbitrage.

Méthode et traçabilité

Nous conservons les originaux et travaillons sur des copies. Chaque observation garde sa source, son horodatage et sa référence. Les dates de première apparition sont distinguées des dates de collecte. Nous séparons faits, hypothèses et inconnues, conservons les cotes Admiralty fournies et évaluons la fiabilité des sources d'enrichissement. Les étiquettes MITRE ATT&CK seront vérifiées à partir des comportements. Les recoupements internes au dossier ne seront pas présentés comme des confirmations indépendantes.

Sources et outils envisagés

Le corpus comprend le Lisez-moi, trois fiches de binaires, 40 indicateurs en CSV et JSON, 12 alertes SIEM, le mémo SOC et les journaux bruts. Les deux formats d'indicateurs représentent la même liste. Les deux copies de fiches reçues sont identiques. Les sources externes envisagées sont les documentations officielles MISP, MITRE ATT&CK, OASIS STIX 2.1 et ANSSI, ainsi que des analyses techniques dont la provenance et la pertinence seront évaluées.

MISP sera préparé localement avec Docker, après vérification des ressources. Il servira à structurer les objets, les relations et les classifications de partage. Le graphe sera généré depuis le bundle STIX avec networkx ou Gephi. Le volet Wazuh reste optionnel et dépend d'une machine disposant d'au moins 16 Go de RAM.

Planning prévisionnel sur cinq jours

Jour	Travail prévu	Résultat attendu
J1	Cadrage, inventaire, chronologie et tri initial	Note de cadrage de 2 pages et points à arbitrer
J2	Préparation de MISP, corrélation et enrichissement	Indicateurs organisés et relations sourcées
J3	Chaîne d'attaque, ATT&CK, Diamond Model et attribution	Cartographie et argumentation de confiance
J4	Rapports et rédaction des règles Sigma	Rapports stratégique et tactique avec 10 règles
J5	Notes, export STIX, graphe et soutenance	Dépôt vérifié et présentation préparée

Les dates calendaires seront ajustées au calendrier du formateur. Le rejeu Wazuh ne sera engagé que si les ressources et le temps le permettent, sans retarder les livrables obligatoires.

Répartition proposée dans l'équipe

À confirmer avec le binôme : Safia prendrait en charge la chronologie, l'analyse des preuves, la note d'attribution et la synthèse pour la direction. Laurent prendrait en charge MISP, le bundle, le graphe et les détections. La cartographie ATT&CK, la matrice de risques et les notes seraient relues ensemble.

Livrables et critères de vérification

Le dépôt cti-helios-energy réunira la note de cadrage, le rapport stratégique de 2 à 3 pages, le rapport tactique de 8 à 12 pages avec au moins 10 règles Sigma déployables, un bundle STIX 2.1 d'au moins 25 objets liés, le graphe, la note d'attribution, la matrice de risques confidentialité intégrité disponibilité, la note ANSSI et la note de partage communautaire.

Chaque technique et relation devra être rattachée à une preuve. L'attribution exposera ses limites et ses biais. Chaque objet STIX portera sa source et sa date de collecte. La diffusion sera définie selon TLP, en tenant compte du mémo marqué TLP:AMBER ; le dépôt ne sera pas rendu public avant examen du contenu partageable. Les règles non testées seront identifiées comme telles.